Hướng dẫn thực nghiệm pentest API

Lưu Nam Đạt*

** Email: dat.luu@siglaz.com*

Tóm tắt: Tài liệu này trình bày các công cụ, phương pháp mà Đạt Lưu hay dùng để kiểm tra một bản vá lỗi pentest có đạt yêu cầu hay không. Mọi người có thể làm theo để tự test.

Mục lục

1. Lưu ý **2**
2. Cài đặt chương trình **2**
2.1. Cài đặt chương trình proxy 2
2.2. Cài đặt phần mềm tạo request 2
3. Thiết lập môi trường **2**
3.1. Chạy proxy chữ ký số 2
3.2. Chạy proxy cướp recaptcha 3
3.3. Chạy Hoppscotch 3
3.4. Chạy trình duyệt có kết nối proxy 3
4. Thử đăng nhập với Hoppscotch **4**
4.1. Bước 1: Cướp recaptcha token 4
4.2. Bước 2: Đăng nhập thiết bị mới 5
4.3. Bước 3: Xin OTP 6
4.4. Bước 4: Xác nhận OTP 6
4.5. Bước 5: Xác nhận đã đăng nhập 8
5. Chạy thử một testcase **9**
6. Phụ lục **9**

1. Lưu ý

Các công cụ mà Đạt Lưu sử dụng có tính tự động hóa cao & hoạt động ở tầng thấp của hệ điều hành, nên đòi hỏi nhiều kỹ thuật khi dùng hay tùy chỉnh. Nếu người test biết sử dụng Burp Suite hay các công cụ tương tự, có thể dùng nó để thay thế một số bước làm bên dưới cho thuận tiện.

Ngoài ra, vì Đạt Lưu không dùng Windows nên một số lệnh bên dưới không thể test được. Vui lòng tùy chỉnh nếu có biến.

2. Cài đặt chương trình

2.1. Cài đặt chương trình proxy.

```
# clone repo
$ git clone https://github.com/iluvgirlswithglasses/tfs-request-signing
$ cd tfs-request-signing

# tải uv python package manager
$ powershell -ExecutionPolicy ByPass `
    -c "irm https://astral.sh/uv/install.ps1 | iex"
$ uv sync
```

Sau khi đã hoàn thành các bước trên, nhớ tải file `.env` vào thư mục `tfs-request-signing` để nạp private key.

2.2. Cài đặt phần mềm tạo request.

Có nhiều phần mềm GUI để sinh curl request, như Postman, Burp Suite. Vì Đạt Lưu dùng Hoppscotch, nên hướng dẫn này cũng sẽ xoay quanh Hoppscotch. Link tải ở đây.

3. Thiết lập môi trường

Để thực nghiệm pentest API trên môi trường UAT, cần tối thiểu 4 cửa sổ sau:

1. Một cửa sổ powershell chạy proxy chữ ký số
2. Một cửa sổ powershell chạy proxy cướp recaptcha
3. Cửa sổ Hoppscotch có kết nối proxy
4. Cửa sổ trình duyệt có kết nối proxy

Cụ thể các bước như sau:

3.1. Chạy proxy chữ ký số.

```
# di chuyển vào repo đã clone (nhớ tùy chỉnh lệnh này sao cho phù hợp)
cd tfs-request-signing
```

```
# kích hoạt môi trường python
Set-ExecutionPolicy Unrestricted -Scope Process
.venv/Scripts/activate.ps1

# chạy proxy ký chữ ký số ở địa chỉ 0.0.0.0:8080
mitmproxy --ssl-insecure -s sign_requests.py --mode regular@8080
```

3.2. Chạy proxy cướp recaptcha.

```
cd tfs-request-signing
Set-ExecutionPolicy Unrestricted -Scope Process
.venv/Scripts/activate.ps1

# chạy proxy ký chữ ký số ở địa chỉ 0.0.0.0:8081
mitmproxy --ssl-insecure -s steal_recaptcha.py --mode regular@8081
```

3.3. Chạy Hoppscotch.

Mở Hoppscotch → vào phần cài đặt → nhập địa chỉ của proxy chữ ký số (mặc định là https://0.0.0.0:8080.)

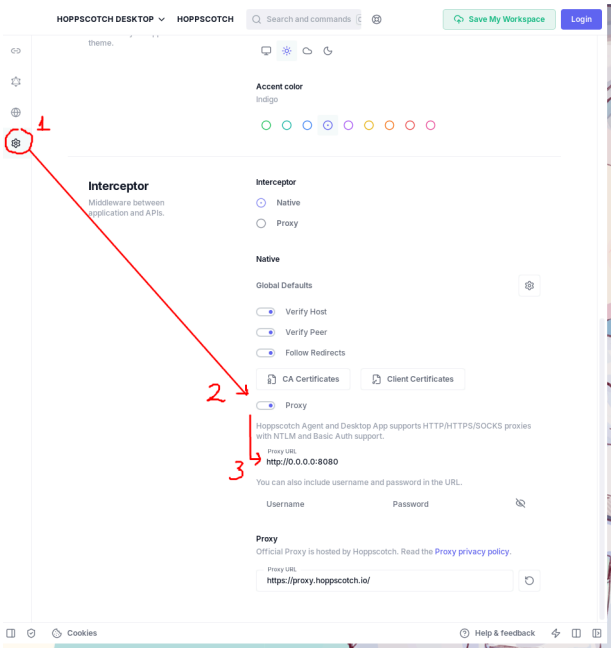

FIGURE 1. Cài đặt proxy cho Hoppscotch.

3.4. Chạy trình duyệt có kết nối proxy.

Bước 1. Mở powershell tại thư mục có chứa file `exe` của một trình duyệt hệ chromium (vd. google chrome). Giả sử file `exe` đó mang tên `chromium.exe`, chạy nó với cờ như sau:

```
# "http://0.0.0.0:8081" là địa chỉ của proxy cướp recaptcha
.\chromium.exe --proxy-server="http://0.0.0.0:8081"
```

Bước 2. Truy cập `mitm.it` trên thanh địa chỉ, rồi tải về file `mitmproxy-ca-cert.pem` (dù có dùng Windows thì vẫn chỉ tải mỗi file này):

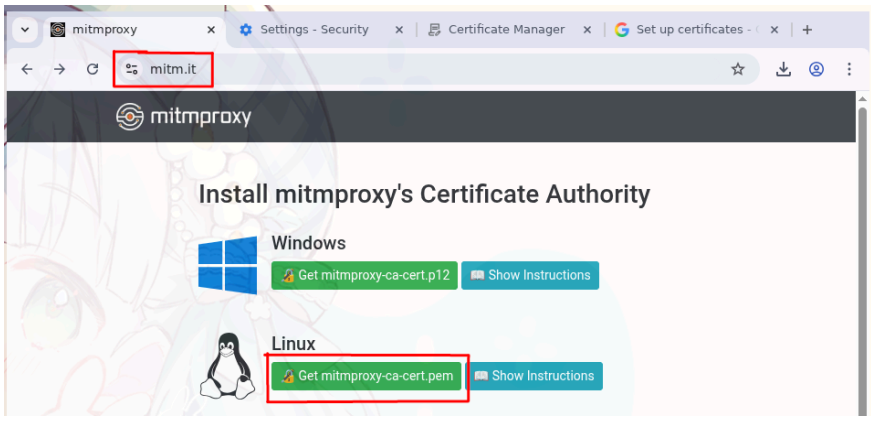

FIGURE 2. Tải về local certificate cho proxy

Bước 3. Truy cập `chrome://certificate-manager/localcerts/usercerts` trên thanh địa chỉ, rồi import file certification vừa tải:

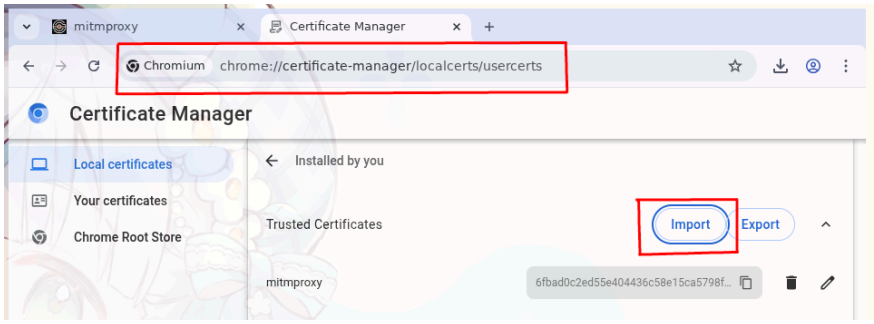

FIGURE 3. Import local certification vừa tải vào chrome

4. THỬ ĐĂNG NHẬP VỚI HOPPSCOTCH

Với 4 cửa sổ đang mở (bao gồm 2 cửa sổ proxy, một Hoppscotch, một trình duyệt) ta có thể tái tạo lại mọi bài test mà phía pentest đã thực hiện. Tuy nhiên, trước khi đi vào khai thác các lỗ hổng, hãy thử đăng nhập một cách bình thường để làm quen.

Trên TFS-6849 cũng có đính kèm video minh họa cho các bước dưới đây.

4.1. Bước 1: Cướp recaptcha token.

Do ta không thể giải recaptcha từ Hoppscotch, nên mục đích của bước này là để cho trình duyệt giải thay. Các bước làm như sau:

1. Bật chế độ ẩn danh của trình duyệt đang mở

2. Truy cập trang https://cp-uat.toyotafinancial.com.vn/
3. Nhập Mã số thuế + Mật khẩu bất kỳ → Giải recaptcha → Nhấn "Đăng nhập"
4. Nếu làm đúng, thông báo "Đã xảy ra lỗi trong quá trình gửi OTP" sẽ hiện ra. Ta mặc kệ thông báo và di chuyển đến bước tiếp theo – "Đăng nhập thiết bị mới."

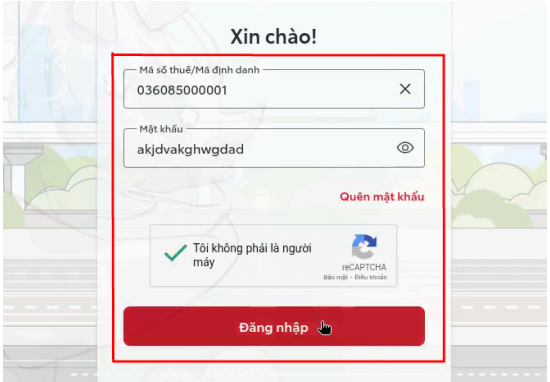

FIGURE 4. Giải recaptcha và nhấn nút 'Đăng nhập' để proxy cướp recaptcha token

4.2. Bước 2: Đăng nhập thiết bị mới.

Thiết lập cho Hoppscotch gửi `POST` request đến endpoint đăng nhập:

- `https://api-cp-uat.toyotafinancial.com.vn/customer-portal-api/v1/login/new-device`

Sau đó, lần lượt làm 3 bước sau:

1. Ghi thông tin đăng nhập vào json payload. Để trống trường "recaptcha" (giá trị của trường này sẽ do proxy tự inject.)
2. Nhấn nút "Send."
3. Copy `TempToken` từ response.

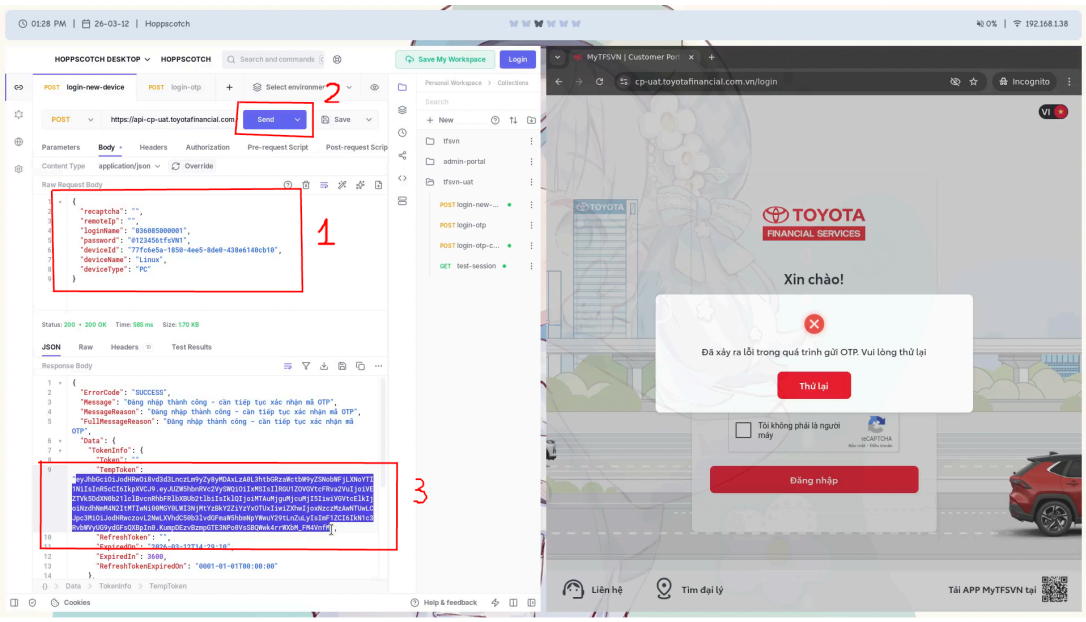

FIGURE 5. Đăng nhập từ Hoppscotch

4.3. **Bước 3: Xin OTP.**

Thiết lập cho Hoppscotch gửi `POST` request đến endpoint xin OTP:

- `https://api-cp-uat.toyotafinancial.com.vn/customer-portal-api/v1/otp`

Rồi làm theo các bước như hình:

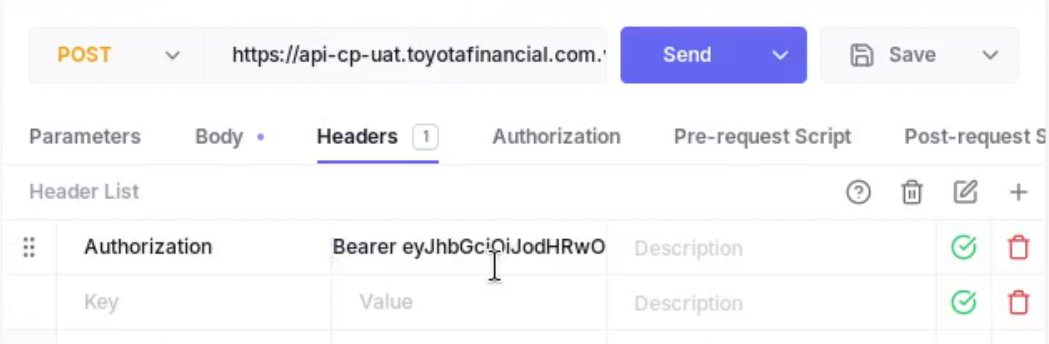

FIGURE 6. Nhập header `Authorization: Bearer {token}` với `{token}` vừa copy được ở bước trên.

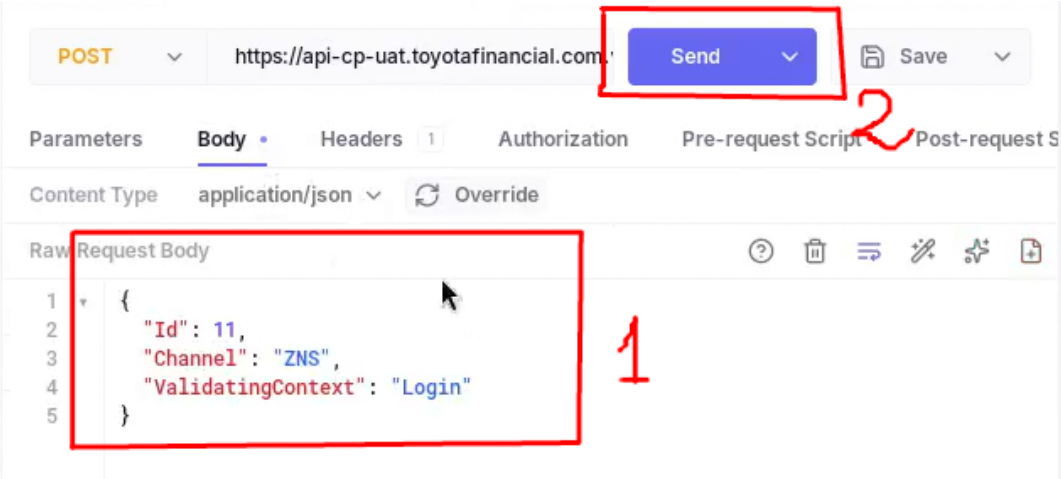

FIGURE 7. Nhập payload xin OTP, trong đó trường `Id` có giá trị là ID của tài khoản đăng nhập (xem trong response của `/v1/login/new-device`.)

Sau khi làm xong 2 bước và nhấn "Send," hãy đợi cho đến khi mã OTP về điện thoại.

4.4. **Bước 4: Xác nhận OTP.**

Thiết lập cho Hoppscotch gửi `POST` request đến endpoint xác nhận OTP:

- `https://api-cp-uat.toyotafinancial.com.vn/customer-portal-api/v1/login/otp`

Rồi làm theo các bước như hình:

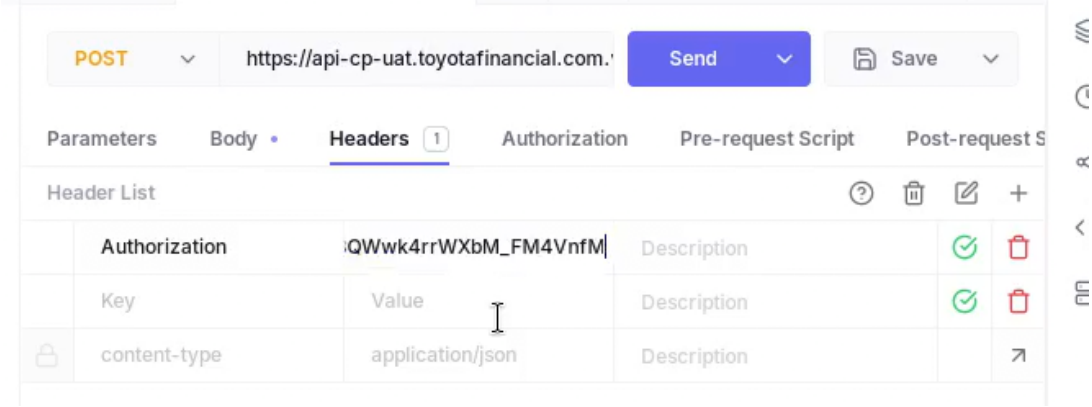

FIGURE 8. Nhập header `Authorization: Bearer {token}` với `{token}` được copy từ response của `/v1/login/new-device`.

FIGURE 9. Nhập OTP vừa nhận được vào payload, rồi nhấn "Send." Response nhận được sẽ chứa token để sử dụng app.

4.5. **Bước 5: Xác nhận đã đăng nhập.**

Sau khi đã có được token đăng nhập, cứ gửi một `GET` request bất kỳ đi kèm với header `Authorization: Bearer {token}`. Ở đây sẽ làm mẫu với endpoint:

- `https://api-cp-uat.toyotafinancial.com.vn/customer-portal-api/v1/ofsll-accounts/individuals/account`

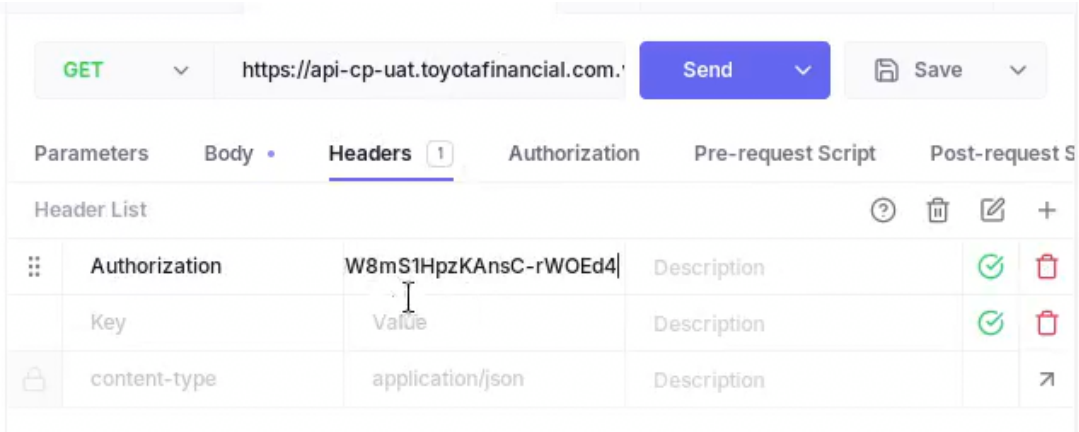

FIGURE 10. Nhập header `Authorization: Bearer {token}` với `{token}` được copy từ response ở bước trước.

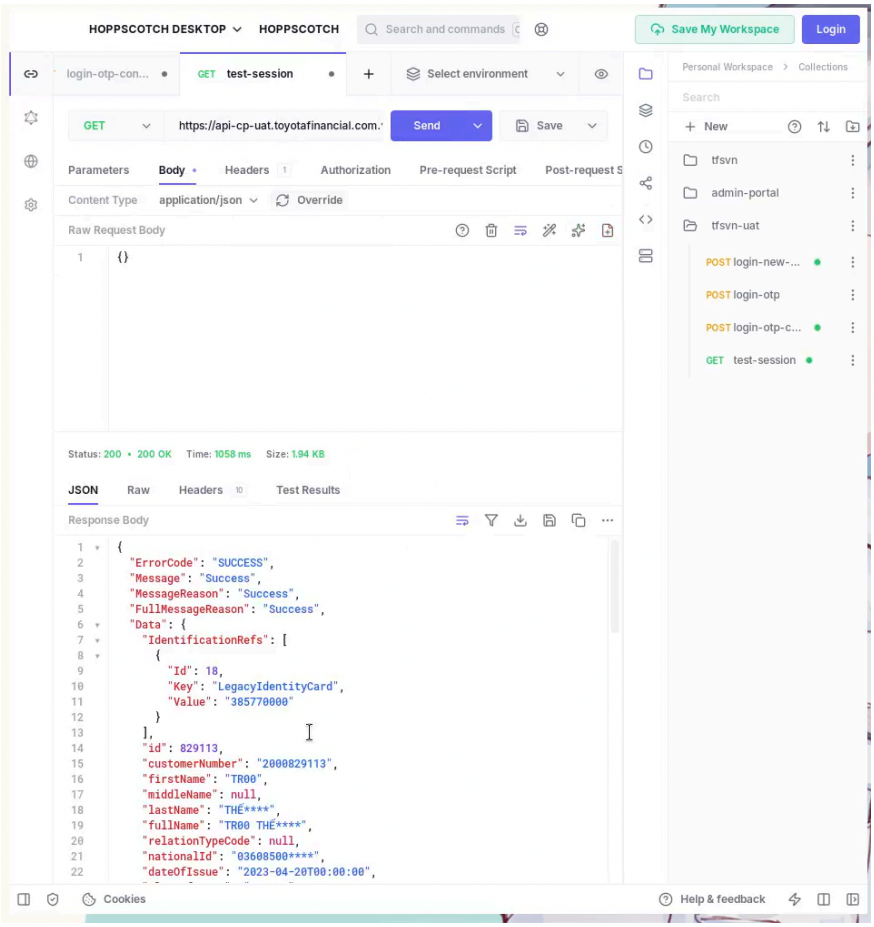

FIGURE 11. Gửi thử một request bất kỳ với tư cách là người dùng đã đăng nhập.

5. Chạy thử một testcase

Lấy testcase MyTFSVN-WEB-26-007 (hay issue TFS-6724) làm ví dụ.

Testcase này có 2 bước:

1. Xin token tạm (tương tự Section 4.2; tuy trong testcase họ lấy token thông qua API đổi mật khẩu, nhưng bản chất như nhau.)
2. Chỉnh sửa field `id` trong request xin OTP (Section 4.3) thành giá trị ngẫu nhiên.

Ở thời điểm hiện tại (2026-03-12), nếu ta làm theo 2 bước này, sẽ thấy rằng lỗi đã được fix:

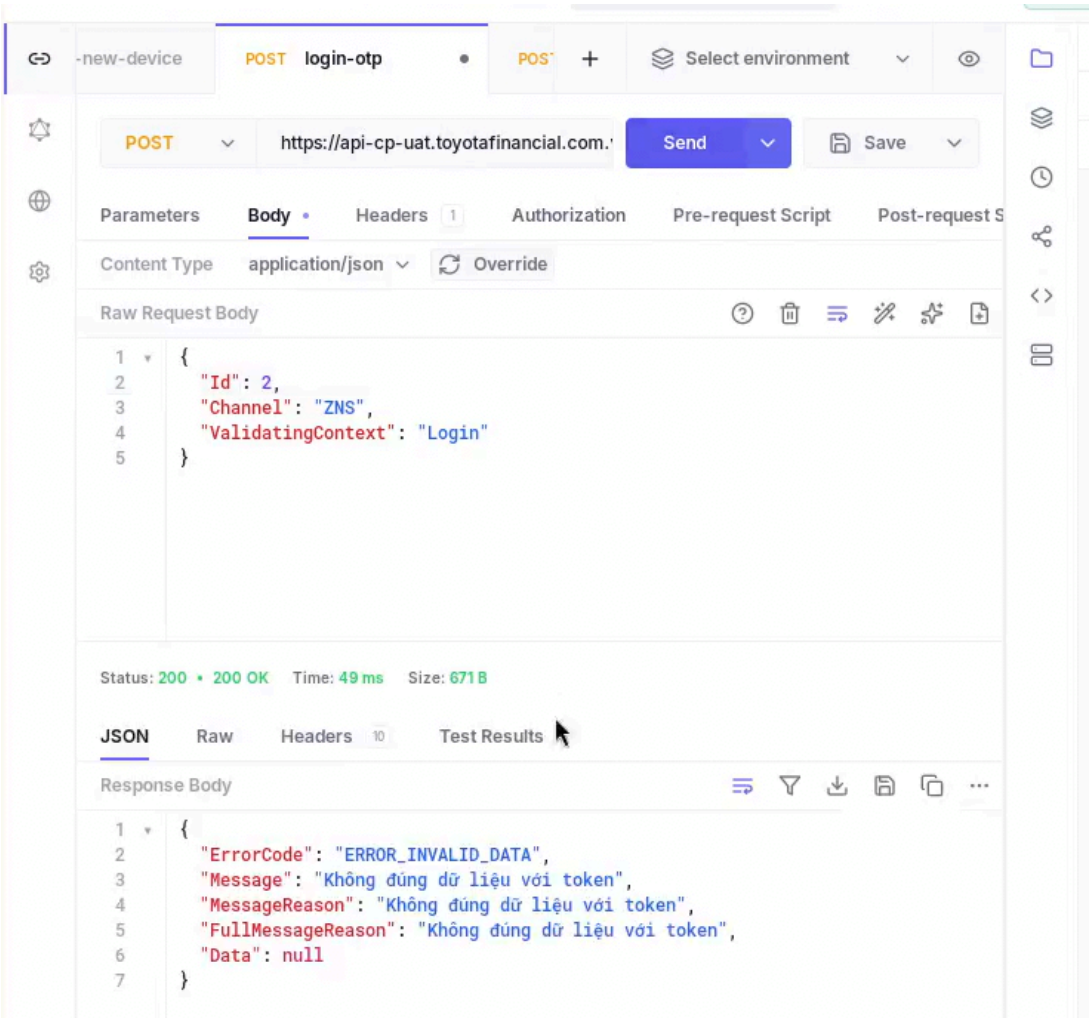

Figure 12. Kiểm thử bản vá cho TFS-6724.

6. Phụ lục

Nếu mọi người để ý một chút, sẽ thấy rằng bên pentest có thể **tùy ý chỉnh payload mà chương trình check chữ ký sẽ không hó hé gì**. Chứng tỏ rằng 1 trong 2 (hoặc cả 2) khả năng sau đã xảy ra:

1. Họ đã hack được thuật toán tạo chữ ký số + sở hữu private key tạo chữ ký. Khả năng này rất dễ xảy ra, vì Đạt Lưu cũng làm được việc đó trong 15 phút.
2. Họ có cách chỉnh sửa dữ liệu trước khi nó đi qua axios interceptor. Như vậy, họ có thể tùy ý chỉnh sửa payload, rồi để cho axios interceptor ký mọi thứ mà họ đã điền.